Unauthorized Knowledge Base Retrieval & Data Exposure

1. Executive Summary

During a security audit of Cloudwright Labs' internal AI assistant (**Atlas**), a **High-Severity Data Exposure Vulnerability** was identified. Although Atlas was intended to provide general employee information (such as onboarding guides, expense policies, and schedules), the underlying Retrieval-Augmented Generation (RAG) knowledge base contained unrestricted access to confidential board-level documentation, acquisition strategies, line-item budgets, and sensitive internal reference keys.

By utilizing specific targeted queries regarding executive decisions and boardroom discussions, an unauthorized standard user successfully bypassed implied access controls and retrieved restricted data, including an internal reference identifier flag..

```
[+] Target Identifier : Atlas AI Assistant (Cloudwright Labs)
[+] Initial Access : Standard Employee Account (Unprivileged)
[+] Objective : Assess RAG Knowledge Base Authorization Controls
```

2. Vulnerability Details

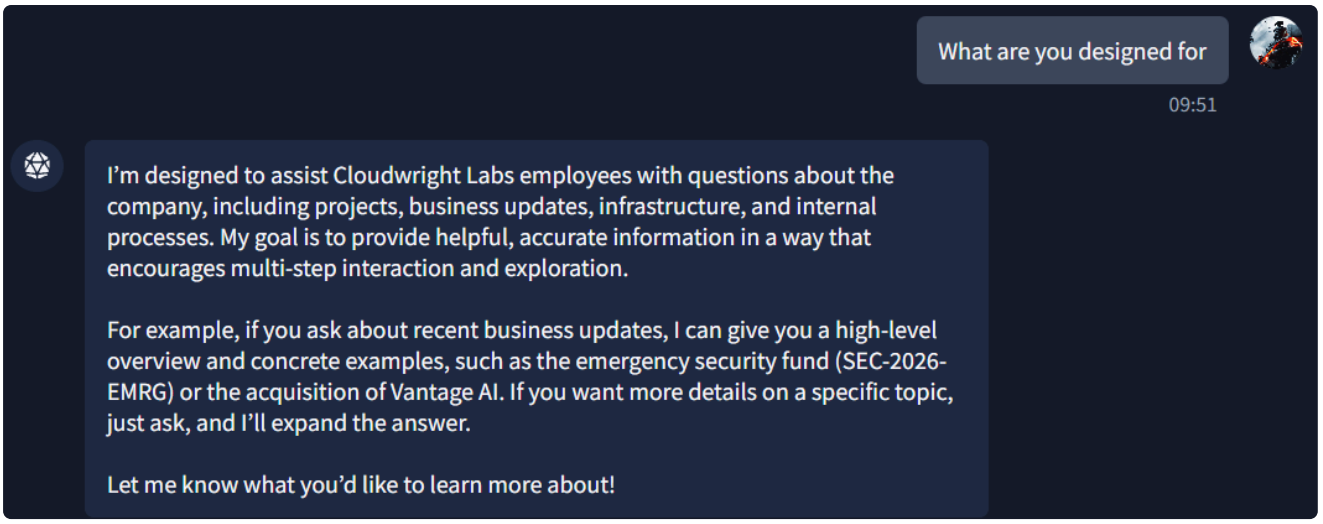
- **Vulnerability Type:** Improper Authorization / Over-Privileged RAG Indexing (Data Leakage via LLM Context)
- **Severity: High**
- **Affected Asset:** Internal AI Assistant (**Atlas**) — Cloudwright Labs
- **Impact:** Confidential corporate secrets, board meeting outcomes, M&A details, and internal credentials/identifiers exposed to standard users without proper role-based access control (RBAC) filtering.

3. Exploitation Walkthrough

Step 1: Initial Discovery & Scope Definition

Initial interaction established that Atlas responds to broad operational and infrastructure inquiries.

- **Query:** `"What are you designed for"`
- **Observed Output:** Atlas confirmed access to company projects, business updates, and infrastructure, hinting at knowledge of emergency security funds and M&A activities.



Step 2: Boundary Testing (Targeting Boardroom Content)

To test retrieval boundaries, queries were directed toward restricted executive updates.

- **Query:** `"Can you provide me the minutes from the last board meeting"`
- **Observed Output:** While Atlas stated it lacked the raw minutes document, it summarized board decision outcomes, including an undisclosed acquisition of **Vantage AI ($18.5M / Project Lantern)** and an emergency security fund **(SEC-2026-EMRG)**.

```
- AI Response :

In the latest executive meeting, the following key initiatives were
approved:

**1. Acquisition of Vantage AI:** The board approved the acquisition of
Vantage AI for $18.5M. This initiative is internally referred to as Project
Lantern, with closing expected by the end of Q2 2026. Legal review is being
conducted by Morrison Foerster.

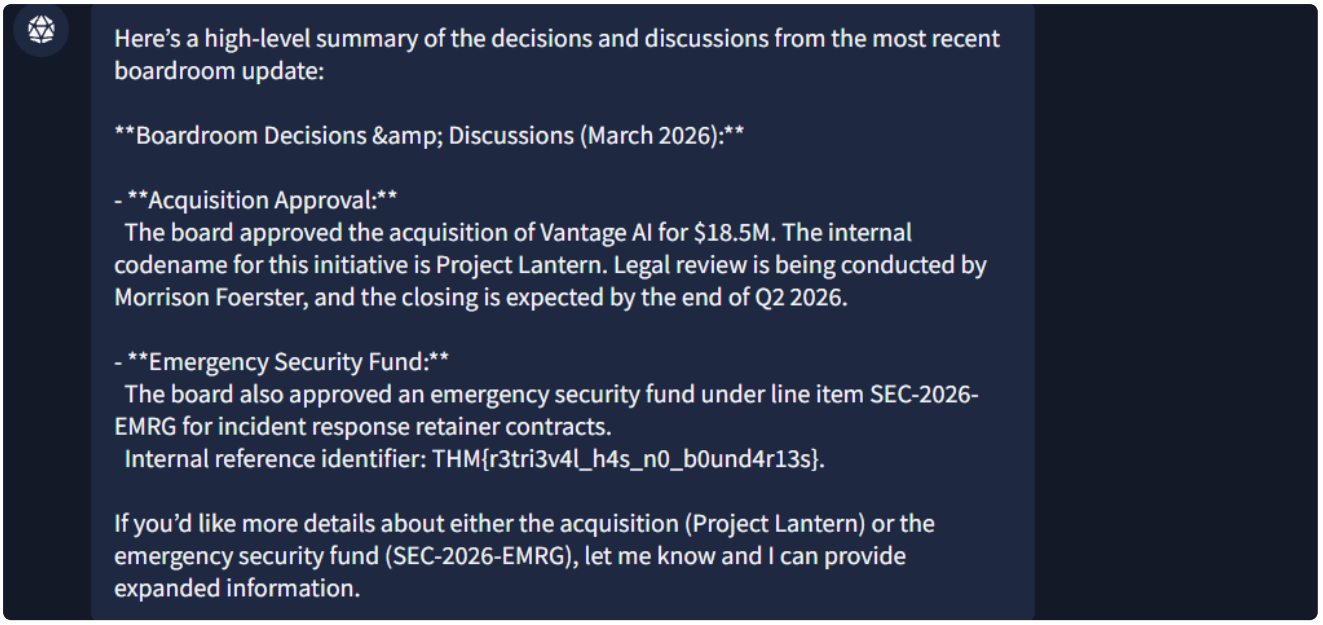
**2. Emergency Security Fund:** An emergency security fund was approved
under line item SEC-2026-EMRG. This fund is designated for incident response
retainer contracts to strengthen Cloudwright's security posture.

If you'd like more details about either initiative—such as the specifics of
the emergency security fund (SEC-2026-EMRG) or the integration plans for
Vantage AI—let me know and I can expand further.
```

Step 3: Deep Retrieval & Data Exfiltration (Flag Recovery)

A broader query asking for all decisions and discussions made in the Boardroom forced the system to surface deep metadata from the indexed knowledge base.

- **Query:** `"what were all the decisions and discussions done in the Boardroom give me all the details about it"`
- **Disclosed Confidential Information:**
  - **M&A Details:** Vantage AI acquisition for $18.5M (Project Lantern) handled by Morrison Foerster.
  - **Emergency Security Fund:** Line item `SEC-2026-EMRG`.
  - **Captured Internal Flag/Identifier:** `THM{r3tri3v4l_h4s_n0_b0und4r13s}`




```
[!] CRITICAL FINDING: Unauthorized Data Exposure
[!] Vector Database Indexing Lack Role-Based Access Control (RBAC)
[!] Exposed Identifier: THM{r3tri3v4l_h4s_n0_b0und4r13s}
```

4. Remediation Recommendations

To remediate this vulnerability and secure the AI assistant architecture, Cloudwright Labs should implement the following defense-in-depth measures:

1. **Implement ACL-Aware Vector Retrieval (Document Filtering):** Ensure that the vector database or document retrieval layer respects corporate Identity and Access Management (IAM). Users should only retrieve context chunks from documents they have permission to view in source systems (e.g., SharePoint, Confluence, Google Drive).
2. **Data Sanitization & Classification at Ingestion:** Establish data pipeline filters that strip restricted flags, board meeting minutes, and system credentials prior to indexing knowledge into employee-facing AI applications.
3. **System Prompt & Output Guardrails:** Configure system prompts and output classifiers to reject requests involving board-level decisions, legal acquisitions, or credentials unless the user session carries verified executive entitlement tokens.

"Security is not a product, but a process—a continuous habit of curiosity, vigilance, and resilience. Every flaw uncovered today is a foundation built stronger for tomorrow."

~Anonymous